Technical Risk Treatment Lab Report

Organization: Northbridge Services **Student:** Chijioke Ezumah **Course:** GRC103 Module 3 **Date:** November 7, 2026

1. EXECUTIVE MANAGEMENT SUMMARY

Northbridge Services executed a structured technical risk treatment project on its core internal web infrastructure to eliminate legacy exposure, restrict network perimeters, prevent unauthorized file publication, and validate data recovery capabilities without causing service interruption to approved operations.

> **Key Achievement Summary:** Overall operational risk posture score reduced from **68 (High/Critical)** to **19 (Low/Medium)** through integrated implementation of risk Avoidance, Prevention, Detection, and Business Continuity controls.

Summary of Baseline vs. Post-Treatment Risk Posture

Risk ID & Asset	Baseline Threat & Weakness	Initial Score	Applied Treatment Control	Residual Score	Status
R1: Legacy Endpoint	Unmonitored Python service on port 8080	20 (Critical)	Avoidance (Service disabled & mask)	4 (Low)	Remediated
R2: Data Archive	Directory index & direct archive retrieval	16 (High)	Prevention (Path move & Nginx deny)	4 (Low)	Remediated
R3: Network Boundary	Unrestricted subnet access to TCP 80	16 (High)	Prevention (UFW IP whitelisting)	6 (Medium)	Controlled
R4: Portal Integrity	Operational file deletion / corruption	16 (High)	Corrective (Hash-verified backup)	5 (Medium)	Validated

Financial Analysis & Treatment Strategy Overview

- **Total Year-1 Implementation Cost:** $510.00 (Hardening labor & maintenance + Managed Backup setup and annual fees).
- **Financial Benefit (Option B Scenario):** Baseline ALE of $1,000 reduced to Residual ALE of $200, yielding an **Annual Benefit of $800.00** and a **First-Year Net Benefit of $440.00**.
- **Recovery Timing (RTO):** Actual emergency restoration accomplished in **2 minutes, 15 seconds** with 100% cryptographic SHA-256 integrity match.

2. BASELINE TECHNICAL ENVIRONMENT & INITIAL MEASUREMENT

The baseline environment was configured on Ubuntu Server (`192.168.56.20`) and probed from Kali Linux (`192.168.56.10`). Initial scanning confirmed two exposed TCP endpoints and published dummy archives.

```
# Baseline Port Scan Verification (Kali -> Ubuntu)
$ nmap -sT -p 80,8080 192.168.56.20 -oN baseline-ports.txt
PORT     STATE SERVICE
80/tcp   OPEN  http
8080/tcp OPEN  http-proxy

# HTTP Directory Listing Baseline Check
$ curl -i "http://192.168.56.20/archive/dummy-records.txt"
HTTP/1.1 200 OK
DUMMY RECORD A001 - training only
```

3. RISK TREATMENT IMPLEMENTATION & VALIDATION

Step 6: Avoidance Implementation (Legacy Workflow Retirement)

To eliminate shadow service exposure, the deliberate decision was taken to permanently retire `grc-legacy.service` on TCP port 8080.

Change Record Field	Details / Execution Parameters
Proposed Change	Stop and disable systemd unit `grc-legacy.service` running Python HTTP on port 8080.
Business Impact	Zero disruption to production portal; legacy endpoint confirmed obsolete.
Approval Authorization	*Simulated Approval* — GRC Analyst (Chijioke Ezumah) & Operations Lead.
Execution Command	`sudo systemctl disable --now grc-legacy`
Rollback Procedure	`sudo systemctl enable --now grc-legacy` (Tested and re-disabled).

```
# Validation of Avoidance (Kali Linux)
$ nmap -sT -p 80,8080 192.168.56.20 -oN avoidance-ports.txt
PORT     STATE  SERVICE
80/tcp   open   http
8080/tcp closed http-proxy

$ curl -i "http://192.168.56.20:8080/"
curl: (7) Failed to connect to 192.168.56.20 port 8080: Connection refused
```

> **Risk Avoidance Analysis:** Disabling the service avoids risks tied to port 8080. However, it does *not* eliminate risks to the primary web service on port 80, which requires distinct preventive controls.

Step 7: Hardening Publication & Disabling Directory Listings

Data files were relocated outside the web root to `/srv/grc-private/`, and Nginx was configured to reject requests to the retired path and disable autoindexing.

```
# Nginx Site Hardening Configuration (/etc/nginx/sites-available/grc-lab)
server {
    listen 80;
    server_name _;
    root /var/www/grc-lab;
    access_log /var/log/nginx/grc_access.log combined;
    error_log /var/log/nginx/grc_error.log;

    location / { autoindex off; }
    location /archive/ { deny all; }
}
```

Target URI	Expected Response	Actual Response	Validation Finding
`http://192.168.56.20/public/`	HTTP 200 OK	HTTP 200 OK	Approved content accessible
`http://192.168.56.20/`	HTTP 403 Forbidden	HTTP 403 Forbidden	Directory listing blocked
`http://192.168.56.20/archive/`	HTTP 403 Forbidden	HTTP 403 Forbidden	Path restriction enforced

Note on Preventive Defense: Disabling `autoindex` alone hides folder listings but does not prevent direct access if a path is known. Relocating files outside the document root guarantees physical non-reachability.

Step 8: Network Perimeter Filtering with UFW

UFW was enabled with a default-deny incoming policy, permitting HTTP traffic solely from Kali's approved host IP (`192.168.56.10`). An secondary IP (`192.168.56.11`) was bound to Kali to simulate an unauthorized source.

```
# Approved vs Unapproved Source Test Verification
$ curl -i "http://192.168.56.20/public/"  # From 192.168.56.10 -> HTTP 200 OK

$ curl --interface 192.168.56.11 --connect-timeout 5 "http://192.168.56.20/public/"
curl: (28) Failed to connect to 192.168.56.20 port 80: Connection timed out
```

4. DETECTION, RECOVERY & OPERATIONAL GOVERNANCE

Step 9: Log Evidence Correlation

Log entries were correlated across Nginx application access logs and UFW kernel logs to verify detective visibility.

```
# Nginx Access Log Extract (/var/log/nginx/grc_access.log)
192.168.56.10 - - [07/Nov/2026:15:10:02 +0100] "GET /public/ HTTP/1.1" 200 25 "-" "curl/8.8.0"
192.168.56.10 - - [07/Nov/2026:15:10:15 +0100] "GET /archive/ HTTP/1.1" 403 153 "-"
"curl/8.8.0"

# UFW Firewall Block Log Extract (/var/log/ufw.log)
Nov  7 15:12:30 ubuntu-server kernel: [UFW BLOCK] IN=enp0s3 OUT= SRC=192.168.56.11
DST=192.168.56.20 PROTO=TCP SPT=48920 DPT=80 SYN
```

Test ID	Source IP	Requested Resource	Expected Result	Actual Log Source & Entry
TST-01	192.168.56.10	`/public/`	HTTP 200 OK	`grc_access.log`: Status 200 recorded
TST-02	192.168.56.10	`/archive/`	HTTP 403 Forbidden	`grc_access.log`: Status 403 recorded
TST-03	192.168.56.11	`/public/`	TCP Timeout	`ufw.log`: Kernel drop event logged

> **Log Architecture Architecture Note:** Blocked packets from `192.168.56.11` are dropped at the kernel network stack by UFW and do *not* appear in Nginx access logs because no TCP session or HTTP handshake is established.

Step 10: Backup, Integrity Check & Recovery Timing

A compressed, permission-restricted archive was created, and SHA-256 baseline hashes were generated prior to executing an outage simulation.

```
# Outage Simulation & Verified Restoration Sequence
$ sha256sum /var/www/grc-lab/public/index.html | tee ~/portal-before.sha256
e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855  index.html

$ date -Is # Start Time: 2026-11-07T15:30:00+01:00
$ sudo rm /var/www/grc-lab/public/index.html  # Simulated Destruction

# Restoration Command Execution
$ sudo tar -xzpf /srv/grc-backups/public-before-test.tgz -C /var/www/grc-lab
$ sha256sum -c ~/portal-before.sha256
/var/www/grc-lab/public/index.html: OK
$ date -Is # End Time:   2026-11-07T15:32:15+01:00
```

- **Measured Recovery Time Objective (RTO):** 2 minutes, 15 seconds.
- **Integrity Verification:** Cryptographic SHA-256 hash match confirmed zero data alteration.
- **Architectural Limitation:** Same-host local backups protect against accidental deletion but fail under host hypervisor corruption, hardware failure, or full system compromise. Offsite replication is required.

Ongoing Operational Monitoring Plan

Metric / Check	Responsible Owner	Frequency	Threshold Condition	Escalation Action
Portal Availability	SysAdmin Team	Every 5 Mins	HTTP Status ≠ 200 on `/public/`	Trigger emergency restore script
Drift / Open Ports	SecOps Team	Daily Scan	Any open port ≠ TCP 80	Auto-kill process & alert GRC Lead
Backup Verification	Backup Admin	Monthly	SHA-256 Mismatch / RTO > 15m	Re-index backup & escalate to Manager

5. TREATMENT DECISIONS & FINANCIAL COST ANALYSIS

Step 11: Risk Transfer & Risk Acceptance Modeling

Risk Transfer Evaluation (Option B)

- **Vendor Scope:** $120 setup + $20/mo offsite repository storage.
- **Customer Obligations:** Key management, agent configuration, integrity tests.
- **Proposed Clause:** *"Vendor guarantees repository availability; data integrity and operational restoration readiness remain customer duties."*
- **GRC Principle:** Contracts transfer financial risk, not fiduciary responsibility.

Risk Acceptance Record (HTTP Retention)

- **Owner:** Head of IT / GRC Lead
- **Residual Score:** 6 (Medium)
- **Rationale:** Host-only lab environment with non-sensitive dummy data.
- **Expiry & Review:** 14 Days (Expires Nov 21, 2026).
- **Trigger:** Production data upload or external network bridging.

Step 12: Cost Comparison & ALE Financial Model

Option Selection: Combined **Option A (Hardening Work)** and **Option B (Managed Backup)**.

```
Option A (Labor 4h @ $25/h + $50 Maint)  = $150.00
Option B ($120 Setup + $20/mo x 12)       = $360.00
Total First-Year Strategy Implementation  = $510.00  (Option C TLS deferred)
```

Illustrative Risk Financial Calculation (Option B Backup Scenario)

Financial Metric	Formula / Basis	Calculated Value
Baseline Single Loss Expectancy (SLE)	Assumed loss per event	$5,000.00
Annual Rate of Occurrence (ARO)	Assumed frequency	0.20 (Once per 5 years)
Baseline Annual Loss Expectancy (ALE)	$\text{SLE} \times \text{ARO} = \$5,000 \times 0.20$	**$1,000.00**

Financial Metric	Formula / Basis	Calculated Value
Residual SLE & ALE (Post-Control)	Residual loss $1,000 \times 0.20$	**$200.00**
Annual Financial Benefit	$\text{Baseline ALE} - \text{Residual ALE}$	**$800.00**
First-Year Net Benefit	$\text{Annual Benefit} - \text{Option B Cost } (\$360)$	**$440.00**

6. DELIVERABLES PACKAGE & SUBMISSION README MAPPING

The companion archive `submission_evidence.zip` has been structured to validate all evidence requirements without exposing credentials or VM disk images.

```
submission_evidence.zip Structure:
├── README.md                          <- Evidence mapping file
├── outputs/                           <- Command execution outputs
│   ├── baseline-ports.txt
│   ├── baseline-web.txt
│   ├── baseline-listing.txt
│   ├── baseline-file.txt
│   ├── baseline-legacy.txt
│   ├── avoidance-ports.txt
│   ├── avoidance-legacy.txt
│   ├── ufw-status.txt
│   └── portal-before.sha256
├── configs/                           <- Redacted configuration files
│   ├── nginx-grc-lab.conf
│   └── grc-legacy.service
├── logs/                              <- Redacted log extracts
│   ├── nginx_access_redacted.log
│   └── ufw_redacted.log
├── screenshots/                       <- Terminal execution captures
│   ├── 01-baseline-nmap.png
│   ├── 02-avoidance-kali.png
│   ├── 03-ufw-blocked-timeout.png
│   └── 04-hash-verification-success.png
└── financial_model.xlsx               <- ALE & Cost workbook
```